ITEM DESCRIPTION

Title: SOFTWARE ASSURANCE EVALUATION REPORT (SAER)

Number: DI-IPSC-82249A
AMSC Number: 10221
DTIC Applicable: No
Preparing Activity: MDA
Applicable Forms: None

Approval Date: 20210212
Limitation: N/A
GIDEP Applicable: No
Project Number: IPSC-2021-005

Use/Relationship: The Software Assurance Evaluation Report (SAER) documents the tools, techniques, and results of Non Developmental Item (NDI) software (e.g. Commercial /Government/and Open Source) supply chain vulnerability assessments, static source code assessments, dynamic scans and penetration testing assessments, and manual review and testing of cybersecurity functions.

This Data Item Description (DID) contains the format, content, and intended use of information for the data deliverable resulting from the work task described the contract. This DID supersedes DI-IPSC-82249.

Requirements:

1. **Reference Documents.**

   The applicable issue of the documents cited herein, including their approval dates and dates of any applicable amendments, notices, and revisions, shall be as specified in the contract.

   a. "DoD Developer's Guidebook for Software Assurance," Carnegie Mellon University, Software Engineering Institute (SEI), Federally Funded Research and Development Center (FFRDC). https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=539177
   b. "Program Manager's Guidebook for Software Assurance," Carnegie Mellon University, Software Engineering Institute (SEI), Federally Funded Research and Development Center (FFRDC). https://resources.sei.cmu.edu/library/asset-view.cfm?assetid=538771
   c. "Software Vulnerability Assessment Report (SVAR)," DID Number DI-IPSC-82252, https://assist.dla.mil
   d. "CVE – Common Vulnerabilities and Exposures," Mitre Corporation. CVE is sponsored by the National Cyber Security Division of the U.S. Department of Homeland Security. https://cve.mitre.org/
   e. "CWE – Common Weakness Enumeration," Mitre Corporation. https://cwe.mitre.org/
   f. "CAPEC – Common Attack Pattern Enumeration and Classification," Mitre Corporation. https://capec.mitre.org/

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

g. “CVSS – Common Vulnerability Scoring System,” National Institute of Standards (NIST). https://nvd.nist.gov/vuln-metrics/cvss

h. “SCAP - Security Content Automation Protocol,” National Institute of Standards (NIST). https://csrc.nist.gov/projects/security-content-automation-protocol

i. “SARIF - Static Analysis Results Interchange Format,” OASIS Open Standards Open Source, https://www.oasis-open.org/committees/tc_home.php?wg_abbrev=sarif

j. “A Threat-Driven Approach to Cyber Security,” © 2019 Lockheed Martin Corporation, https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Threat-Driven-Approach.pdf

k. “DoD Risk Management Framework (RMF) Knowledge Service,” https://rmfks.osd.mil/rmf/Pages/default.aspx

2. Format.

The report and data formats shall be as specified in sections 3.5, 3.6, 3.7, and 3.8, unless tailored out in the Contract Data Requirements List (CDRL) (DD 1423). For paragraph 3.6.3 (Static Source Code, Build Environment and Vulnerability Assessment Format), use industry standard formats (e.g., Static Analysis Results Interchange Format (SARIF), Security Content Automation Protocol (SCAP)), and in the native tool format (e.g., Fortify Project Report (.fpr)). If the scan tool does not support industry standards or native tool formatted exports, then .xlm or .csv export shall be provided.

3. Content.

This report shall be divided into paragraphs or their equivalents to establish the context for the content described in later sections

3.1 Reference Documents

This section shall list the number, title, revision, and date of all documents referenced in the report. This section shall also identify the source for all documents not available through normal Government stocking activities.

3.2 Document Management and Configuration Control

This section shall identify the version, release date, and other relevant management and configuration control information associated with the current version of the document. A change history, highlighting significant changes from version to version, shall be included.

3.3 Table of Contents

This section shall index all sections, major paragraphs, subparagraphs and appendices with page numbers.

3.4 Document Scope

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

This section shall be divided into paragraphs covering system and software identification, system overview and document overview.

3.4.1 System and Software Identification

This section shall contain a full identification of the system and the software to which this document applies, including, as applicable, identification number(s), title(s), abbreviation(s), version number(s), and release number(s).

3.4.2 System Overview.

This section shall briefly state the purpose of the system to which this document applies. It shall describe the general nature of the system and software; summarize the history of system development, operation, and maintenance; identify the project sponsor, acquirer, user, developer, and support agencies; identify current and planned operating sites; and list other relevant documents.

3.4.3 Document Overview

This section shall summarize the purpose and contents of the report and shall describe any security or privacy considerations associated with its use.

3.5 Supply Chain Risk Assessment Identification

This section shall contain the results of Non Developmental Item (NDI) software (e.g., Commercial-off-the-Shelve (COTS), Government-off-the-Shelve (GOTS), and Open Source Software (OSS), libraries and dependencies) supply chain risk assessments. It shall be divided into paragraphs covering assessment scope and objectives, methodology, process, tools, delivery with bill of materials, and risk assessment results.

3.5.1 Supply Chain Risk Assessment Scope and Objectives

This section shall contain the technical scope and objectives of the supply chain risk assessment.

3.5.2 Supply Chain Risk Assessment Methodology, Process, and Tools

This section shall document the methodology and process associated with the supply chain risk assessment, which shall address tool automation or manual processes where applicable used during the assessment (e.g., Synopsis BlackDuck, Sonatype Nexus, Open Web Application Security Project (OWASP), Dependency Checker, etc.) to include all applicable limitations and constraints associated with the assessment.

3.5.3 Supply Chain NDI software delivery with Bill of Materials

This section shall identify and provide all NDI software (binaries and source code when available) with a bill-of-material list that shall include software name, version, vendor, type of software (e.g. COTS, GOTS, OSS), license information, known vulnerabilities identification, and integrity check mechanism (e.g. Hash, signed, etc.).

3.5.4 Supply Chain Risk Assessment Results

For each NDI software risk or vulnerability include, where applicable:

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

a. Security-relevant information associated with identified software vulnerability
b. Risk Management Framework (RMF) controls identifier
c. Common Vulnerabilities and Exposures (CVE) identifier
d. Common Weakness Enumeration (CWE) identifier
e. A grading scale to categorize and profile identified software vulnerabilities that captures the impact of the vulnerabilities to the system (e.g. Common Vulnerability Scoring System (CVSS), or tool scoring system)

3.6 Static Source Code Vulnerability Assessment Identification

This section shall contain the results of static source code scans with contractor risk assessments. It shall be divided into paragraphs covering assessment objectives, scope, process, frequency, source code, build environment, scan tools and export format, and assessment results.

3.6.1 Static Source Code Vulnerability Assessment Objectives and Scope

This section shall contain the objectives of the static source code scans, and the technical scope (e.g. percentage of code coverage, lines of code, file count, complexity rating, justification for exclusions from scans, and other statistics the contractor finds significant).

3.6.2 Static Source Code Vulnerability Assessment Process and Frequency

This section shall document the process and frequency of contractor's static source code scan assessments, to include identifying the automation tools and process used during the assessment (e.g. Microfocus Fortify, Synopsis Coverity, or other tools) and all applicable limitations and constraints associated with the assessment.

3.6.3 Static Source Code, Build Environment and Vulnerability Assessment Format

Provide the complete source code, NDI software, detailed instructions for building and compiling the software, the contractor's static source code scan results with developer mitigation comments.

3.6.4 Static Source Code Vulnerability Assessment Results

For each source code software vulnerability identify, where applicable:

a. Security-relevant information associated with each identified software vulnerability. For example: justification of false positive, non-exploitable, lower likelihood or impact and other mitigations that help reduce risk, shall be documented within the source code scan results or in a separate risk assessment report.
b. Application Security and Development (ASD) Security Technical Implementation Guide (STIG) vulnerability identifier
c. Risk Management Framework (RMF) controls identifier
d. Common Vulnerabilities and Exposures (CVE) identifier
e. Common Weakness Enumeration (CWE) identifier
f. A grading scale to categorize and profile identified software vulnerabilities that captures the impact of the vulnerabilities to the system (e.g. Common Vulnerability Scoring System (CVSS) or tool scoring system)

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

3.7 Dynamic & Penetration Testing Vulnerability Assessment Identification

This section shall contain the results of contractor dynamic and penetration testing. It shall be divided into paragraphs covering assessment scope and objectives, methodology, processes, tools identification and format.

3.7.1 Dynamic & Penetration Testing Vulnerability Assessment Scope and Objectives

This paragraph shall contain the technical scope and objectives of the dynamic and penetration tests associated with interface boundary, data input, command flows, weakness in security architecture, and security requirements testing for confidentiality, integrity and availability requirements.

3.7.2 Dynamic & Penetration Testing Vulnerability Assessment Methodology and Process

This section shall document the methodology and process associated with the dynamic and penetration testing assessments, to include addressing tool automation or manual process, where applicable, used during the assessment (e.g. Penetration, dynamic or fuzz testing tool, Unit, Integration, or FQT, and test plans) and all applicable limitations and constraints associated with the assessment.

3.7.3 Dynamic & Penetration Testing Vulnerability Assessment Format

The report shall be in contractor format unless otherwise specified on the Contract Data Requirements List (CDRL) (DD 1423).

3.7.4 Dynamic & Penetration Testing Vulnerability Assessment Results

For each software vulnerability identify where applicable:

a. Security-relevant information associated with identified software vulnerability
b. Application Security and Development (ASD) Security Technical Implementation Guide (STIG) vulnerability identifier
c. Risk Management Framework (RMF) controls identifier
d. Common Vulnerabilities and Exposures (CVE) identifier
e. Common Weakness Enumeration (CWE) identifier
f. Common Attack Pattern Enumeration and Classification (CAPEC) identifier
g. A grading scale to categorize and profile identified software vulnerabilities that captures the impact of the vulnerabilities to the system (e.g. Common Vulnerability Scoring System (CVSS) or tool scoring system)

3.8 Cybersecurity Functional Requirement Testing, Manual Reviews, and Software Development Lifecycle (SDLC) Risk Assessment Identification

This section shall contain the results of contractor cybersecurity functional requirements testing, manual testing, and results from SDLC risk assessment review. It shall be divided into paragraphs covering assessment scope and objectives, methodology, processes, tools, format and results.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

3.8.1 Cybersecurity Functional Requirement Testing, Manual Reviews, and SDLC Risk Assessment Scope and Objectives

This section shall contain the technical scope and objectives associated with software design inspection for flaws or weakness in the security architecture, security requirements testing for confidentiality, integrity and availability and risks within the SDLC as measured by the Defense Information Systems Agency (DISA) Application Security and Development STIG and DoDI 8510.01 Risk Management Framework (RMF) applicable controls, Reference k.

3.8.2 Cybersecurity Functional Requirement Testing, Manual Reviews, and SDLC Risk Assessment Methodology, Processes and Tools

This section shall document the processes used to perform the cybersecurity architecture review, cybersecurity requirements and functional testing for confidentiality, integrity and availability, manual reviews, and SDLC Risk Assessment, to include identifying tools used for automation or manual processes and events where applicable (e.g. Unit testing, Integration Testing, or FQT, and any test plans) and all applicable limitations and constraints associated with the assessment.

3.8.3 Cybersecurity Functional Requirement Testing, Manual Reviews, and SDLC Risk Assessment Format

This section shall be in contractor format unless otherwise specified on the Contract Data Requirements List (CDRL) (DD 1423).

3.8.4 Cybersecurity Functional Requirement Testing, Manual Reviews, and SDLC Risk Assessment Results

For each software vulnerability identify, where applicable:

h. Security-relevant information associated with identified software vulnerability
i. Application Security and Development (ASD) Security Technical Implementation Guide (STIG) vulnerability identifier
j. Risk Management Framework (RMF) controls identifier
k. Common Vulnerabilities and Exposures (CVE) identifier
l. Common Weakness Enumeration (CWE) identifier
m. Common Attack Pattern Enumeration and Classification (CAPEC) identifier
n. A grading scale to categorize and profile identified software vulnerabilities that captures the impact of the vulnerabilities to the system (e.g. Common Vulnerability Scoring System (CVSS) or tool scoring system)

3.9 Vulnerability Risk Identification, Assessment & Mitigation

This section shall provide a matrix using the applicable RMF controls, which maps each vulnerability or risk to an RMF control. Provide contextual analysis of likelihood and impact, which is the unmitigated risk and recommendations for mitigating identified vulnerabilities and risk to an acceptable level. Include a Plan of Actions and Milestones (POAM) addressing each vulnerability or risk and the mitigation(s) as an appendix to the report. The POAM shall be a consolidated summary of vulnerabilities with residual risk, recommended mitigations, schedule and resources required to complete the mitigation.

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.

3.10 Executive Summary

This section shall provide an executive summary of the number and severity of potential vulnerabilities as an appendix to the report. This executive summary can be part of a tool generated report in Portable Document Format (PDF), Hypertext Markup Language never seen (HTML), Microsoft Word (DOC) or other formats or can be provided as a separate briefing in contractor selected format.

3.11 Notes.

This section shall contain any general information that aids in understanding the report (e.g., background information, glossary, rationale). This section shall include an alphabetical listing of all acronyms, abbreviations, and their meanings as used in the report and a list of any terms and definitions needed to understand the report.

3.12 Appendices

Appendices shall provide information published separately for convenience in document maintenance (e.g., charts, classified data, etc.), as necessary. As applicable, each appendix shall be referenced in the main body of the report where the data would normally have been provided. Appendices shall be bound as separate documents for ease in handling. Appendices shall be lettered alphabetically (A, B, etc.).

3.12.1 Requirements Conflicts

Document any contractor proprietary components that were excluded from this report in an appendix, including proposed resolution thereof.

END OF DI-IPSC-82249A

Source: https://assist.dla.mil -- Downloaded: 2026-10-26T11:01Z
Check the source to verify that this is the current version before use.